WPTrace — plan realizacji i kamienie milowe

WordPress Incident Triage & Evidence Correlation · Plan PoC · 11 listopada 2026

PUNKT WYJŚCIA	Istniejący mini-prototyp Python CLI, 6 testów syntetycznych i specyfikacja wykonawcza z 9.11.2026.
CEL	Bezpieczna, lokalna analiza kopii plików WordPress, wybranych danych bazy i logów HTTP z raportem dowodowym.
HORYZONT	12 tygodni orientacyjnie: 1 doświadczony programista Python, wsparcie AI i niezależny przegląd bezpieczeństwa.

01 Harmonogram i bramki odbioru

Kamień milowy	Kiedy	Zakres	Uznajemy za gotowe, gdy…
M0 · Fundament	Tydz. 1	Audyt prototypu; architektura, threat model, kontrakty danych, repo i CI.	Zatwierdzona architektura, schematy, lista luk i testów.
M1 · Bezpieczny import	Tydz. 2–3	CaseManager, SecureIngest, manifest SHA-256, limity zasobów.	Brak zmian w źródłach; testy symlink, traversal i TOCTOU.
M2 · Analiza plików	Tydz. 4–5	Pliki core, wtyczki, motywy; PHP w uploads; checksumy i YARA-X.	Znaleziska z dowodami; testy FP i brak wykonywania PHP.
M3 · Analiza bazy	Tydz. 6–7	JSONL, ograniczony parser mysqldump, role, options, cron, baseline.	Testy prefiksów, serializacji, błędnego SQL; jawne luki analizy.
M4 · Logi i korelacja	Tydz. 8	Apache/Nginx, normalizacja UTC, zdarzenia i oś czasu.	Poprawne referencje; brak nieuzasadnionego wnioskowania o przyczynie.
M5 · Raportowanie	Tydz. 9	Rules Engine, ocena severity/confidence, HTML, JSON, privacy.	Spójność raportów, ochrona przed XSS i wyciekiem sekretów.
M6 · Hardening i QA	Tydz. 10–11	Docker offline, fuzzing, benchmark, pełne testy E2E.	Zweryfikowane ograniczenia runtime i wyniki benchmarków.
M7 · Release Candidate	Tydz. 12	Przegląd seniora, README, dokumentacja, demo i release.	Formalna decyzja GO/NO-GO dla kontrolowanego PoC.

Zależności: M0 → M1 → M2/M3 → M4 → M5 → M6 → M7. Bez przejścia bramki odbioru nie zamykamy kamienia milowego.

02 Oczekiwane rezultaty po etapach

- **Po M1:** Bezpieczny import kopii WordPressa i manifest niezmiennych materiałów dowodowych.
- **Po M3:** Analiza plików i wybranych rekordów DB; wykrywanie anomalii z dowodami i opisem ograniczeń.
- **Po M5:** Raport incydentu z chronologią UTC, oceną pewności, listą dowodów i braków pokrycia.
- **Po M7:** Zweryfikowany demonstrator PoC, komplet testów oraz pakiet przekazania. Nie jest to produkt gotowy do SOC.

03 Warunki akceptacji końcowej

- Sześć scenariuszy pozytywnych P1–P6 daje oczekiwane rezultaty i poprawne odnośniki do dowodów.
- Osiem scenariuszy negatywnych N1–N8 nie generuje nieuzasadnionych silnych alarmów.
- Osiemnaście testów bezpieczeństwa i odporności S-01–S-18 nie ujawnia blockerów.
- Nie następuje wykonanie kodu PHP lub SQL z materiału wejściowego ani modyfikacja źródeł.
- Kontener ma zweryfikowany brak sieci, uprawnienia non-root oraz montowanie materiału read-only.
- Błędy i brakujące dane są wykazywane jako coverage gaps lub INCONCLUSIVE, bez deklaracji „clean”.
- Raporty HTML/JSON są spójne, odporne na XSS i usuwają sekrety oraz zbędne dane osobowe.
- Niezależny przegląd techniczny zatwierdza ryzyka, a wyniki testów i wydajności mają dowody.

04 Priorytety produktu

P0 · wymagane	Import i integralność dowodów; analiza plików, wybranych danych SQL i logów; raporty; bezpieczeństwo i testy negatywne.
P1 · po stabilizacji	Rozszerzenie reguł, dokładność wykrywania, dodatkowe formaty logów, benchmark na większych próbkach.
P2 · po PoC	Panel WWW, multisite, Wazuh/SIEM, kontrolowany kolektor WordPress, lokalny asystent AI.

Poza zakresem pierwszej wersji: automatyczne czyszczenie stron, zdalne skanowanie środowisk produkcyjnych, monitoring ciągły i AI wydające samodzielny werdykt o kompromitacji.

05 Sprint 0 — najbliższy krok techniczny

Cel: ustalić rzeczywisty stan kodu, przed rozszerzaniem funkcji. Obecny prototyp jest punktem startu, ale sześć testów syntetycznych nie potwierdza gotowości PoC.

- **1.** Rozpakować pakiet **WPTrace_Final_Pakiet_2026-11-09.zip** do kontrolowanego repozytorium.
- **2.** Przejrzeć strukturę projektu, zależności, CLI, analizatory i istniejące dane testowe.
- **3.** Uruchomić ponownie sześć testów i zachować komendy, środowisko oraz pełny log.
- **4.** Zmapować wymagania specyfikacji na kod: implemented / partial / missing / unverified.
- **5.** Utworzyć backlog z zadaniami T-001–T-505 i przypisać pierwsze priorytety P0.
- **6.** Zatwierdzić threat model, schematy evidence/observation/finding, testy negatywne i CI.

Produkt Sprintu 0

- Raport stanu prototypu (co działa, co jest tylko zadeklarowane, czego brakuje).
- Lista luk bezpieczeństwa i zależności, z priorytetami P0/P1/P2.
- Zatwierdzony backlog M1, kontrakty danych i kryteria Definition of Done.

06 Ryzyka krytyczne i decyzje projektowe

Fałszywe poczucie bezpieczeństwa	Zawsze pokazywać zakres analizy, braki materiału i status INCONCLUSIVE.
Nieufne materiały dowodowe	Nie wykonywać PHP/SQL; bezpieczny odczyt i limity; izolować uruchomienie w VM.
Fałszywe alarmy	Oddzielić ciężar potencjalnego zagrożenia (severity) od pewności dowodów (confidence).
Wycieki danych	Lokalne przetwarzanie, redakcja sekretów, brak telemetrii oraz retencja po stronie operatora.

07 Definicja sukcesu

WPTrace PoC jest ukończony, gdy bezpiecznie i powtarzalnie analizuje kontrolowany, syntetyczny przypadek incydentu WordPress, wskazuje obserwacje i znaleziska wraz z dowodami, ujawnia ograniczenia oraz tworzy raport pozwalający analitykowi przeprowadzić własną ocenę.

Podstawa: WPTrace — kompletna specyfikacja wykonawcza PoC v1.0 (9.11.2026) oraz pakiet mini-prototypu. Harmonogram 12 tygodni i podział tygodni to szacunek, nie pomiar. Formalna bramka M7 dotyczy PoC, nie wdrożenia produkcyjnego.